STIG and SCAP Documentation

STIG (Security Technical Implementation Guide)

STIG Is it configuration standard developed by DISA to secure information systems by enforcing security best practices. It serves as the primary cyber security blueprint for hardening and securing Department of Defense (DoD) information systems.

- **Configuration based**: It provides specific technical guidance to lock down software and hardware including disabling unnecessary services or enforcing password complexities
- **Allows manual or automated validation:** Manually administrators use checklists to physically verify settings that require human judgment. Automated tools like SCAP (Security Content Automation Protocol) compliance checker allows for rapid scalable scanning of systems

Tools Overview

STIG Viewer	Manual STIG checklist review
SCAP Scanner	Automated compliance scanning
Windows 11 STIG	OS hardening baseline

1. *System Description*

The system assessed is a windows 11 virtual environment configured for use in a lab atmosphere. The system is primarily used for learning testing and validating security controls and hardening techniques.

- Operating System: Windows 11 Pro
- Environment: Non-Production
- Domain: Non-Domain Joined
- Network: Local network with internet access.

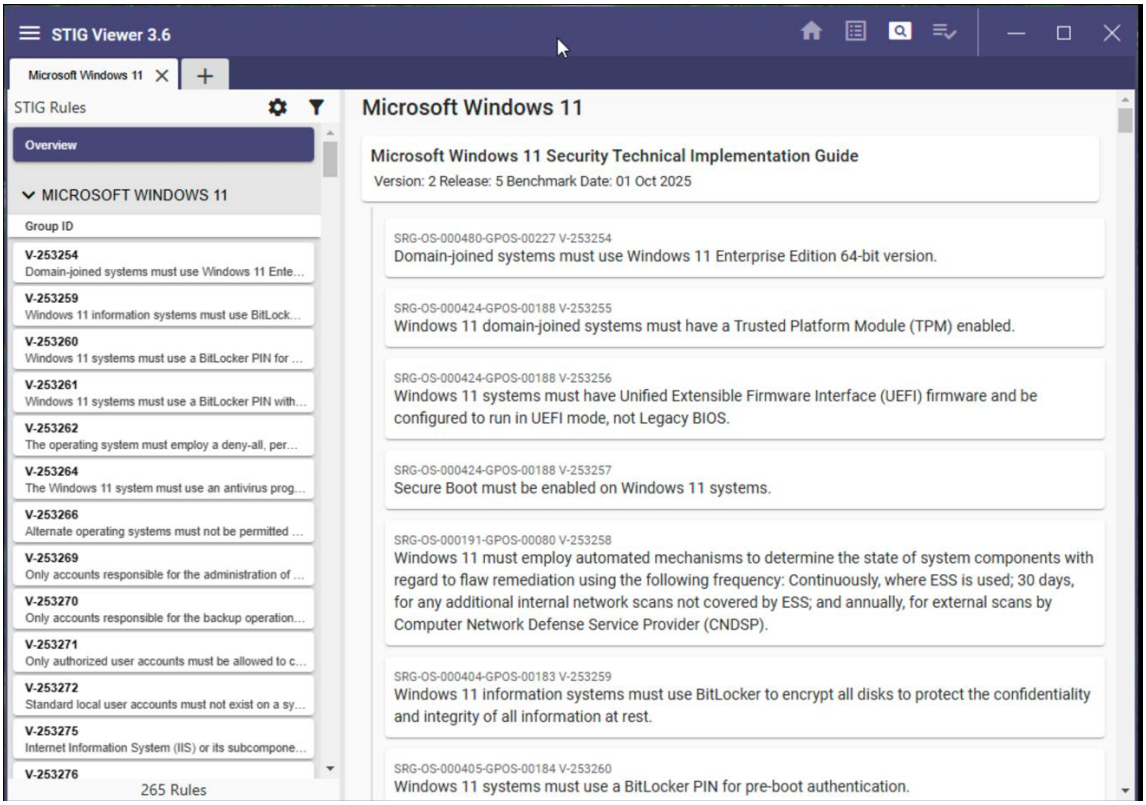
2. *STIG Implementation Process*

→ The windows 11 security technical implementation guide was selected based on the operating system installed on the system this thick provides configuration requirements intended to harden windows 11 systems

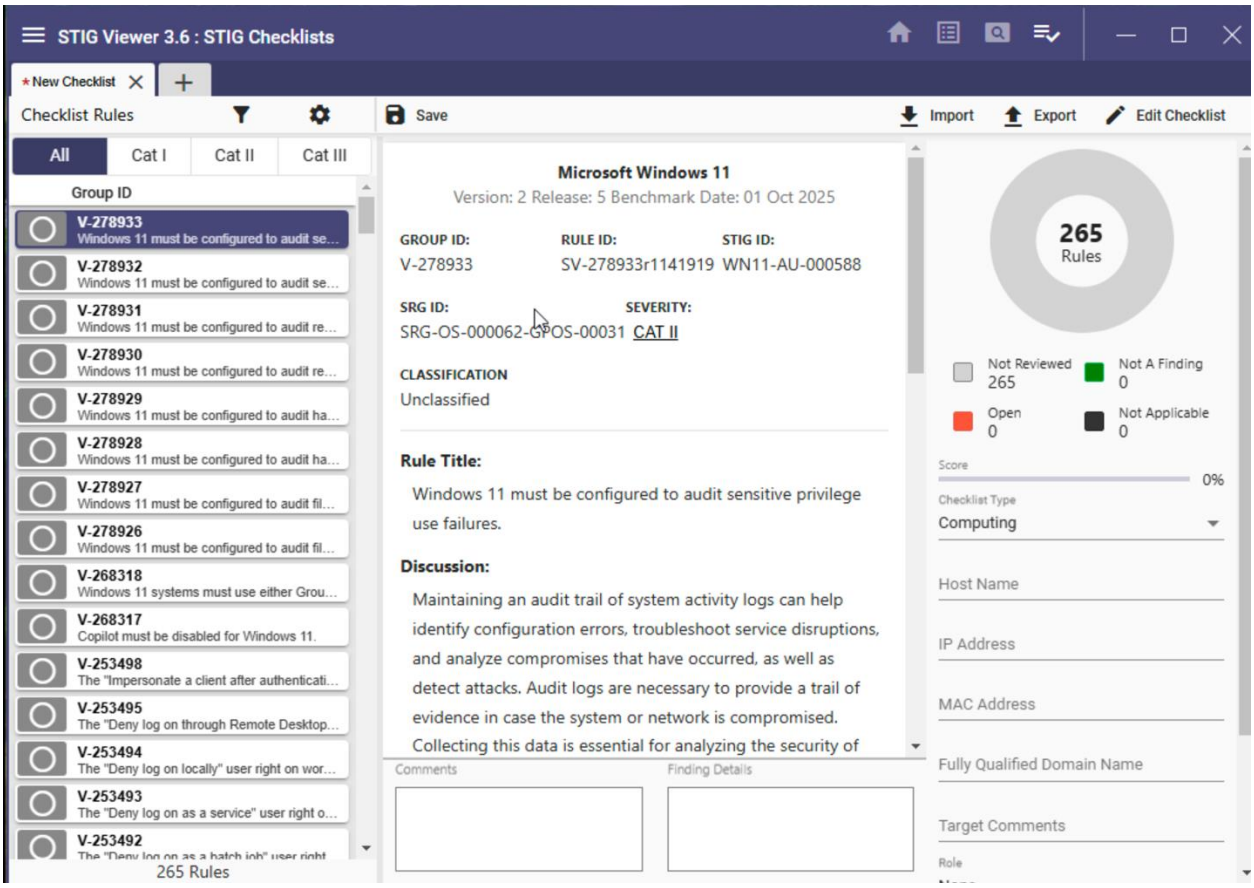
→ The following statuses are used

- Not a finding (NF): The system complies with the STIG requirement.
- Open (O): The system does not meet the requirement and requires remediation
- Not Applicable (NA): The control does not apply to the system configuration
- Not Reviewed (NR): The control was not evaluated during this assessment

3. *STIG Findings Summary*



Above is an example STIG Guide with its check list below.



- *These will be used to perform SCAP scans and review them.*

SCAP (Security Content Automation Protocol)

The Security Content Automation Protocol (SCAP) is the standardized framework used to automate the assessment of system security configurations. While STIGs define the required security settings and hardening guidelines, SCAP provides the mechanism to automatically evaluate those guidelines against the system.

- STIG Serves as the security baseline defining what a secure system looks like. SCAP serves as the validation engine, determining whether the system meets those requirements.

The SCAP results interface provides a visual categorized summary of system compliance against STIG based security benchmarks. This view allows administrators to quickly assess the system security by highlighting compliant configurations, misconfigurations, and non-applicable controls.

→ SCAP results are grouped into several categories to indicate the systems compliance status and associated security risk.

Table 1-1: Vulnerability Severity Category Code Definitions

Category	DISA Category Code Guidelines
CAT I	Any vulnerability, the exploitation of which will **directly and immediately** result in loss of Confidentiality, Availability, or Integrity.
CAT II	Any vulnerability, the exploitation of which **has a potential** to result in loss of Confidentiality, Availability, or Integrity.
CAT III	Any vulnerability, the existence of which **degrades measures** to protect against loss of Confidentiality, Availability, or Integrity.

An example of the scan is shown below.

All Settings Report - Microsoft Windows 11 STIG SCAP Benchmark

SCAP Compliance Checker - 5.12.1

Score | System Information | Content Information | Results | Detailed Results

Score

35.92%

Adjusted Score: 35.92%
Original Score: 35.92%
Compliance Status: RED

Pass:	74	Not Applicable:	9
Fail:	132	Not Checked:	0
Error:	0	Not Selected:	0
Unknown:	0	Informational:	0
Fixed:	0	Total:	215

BLUE: Score equals 100
GREEN: Score is greater than or equal to 90
YELLOW: Score is greater than or equal to 80
RED: Score is greater than or equal to 0

System Information

Target Hostname:	DESKTOP-D9AJHAV
Operating System:	Microsoft Windows 11 Pro
OS Version:	24H2
Domain:	
FQDN:	DESKTOP-D9AJHAV.
Processor:	Apple silicon
Processor Architecture:	ARMv8 (64-bit) Family 8 Model 0 Revision 0
Processor Speed:	2000 mhz
Physical Memory:	4096 mb
Manufacturer:	VMware, Inc.
Model:	VMware20,1
Serial Number:	C18F0EA5F17C4D56

Results: High Severity (CAT I)

Automated Checks

- V-253259 - Windows 11 information systems must use BitLocker to encrypt all disks to protect the confidentiality and integrity of all information at rest. - Fail
- V-253260 - Windows 11 systems must use a BitLocker PIN for pre-boot authentication. - Fail
- V-253263 - Windows 11 systems must be maintained at a supported servicing level. - Pass
- V-253265 - Local volumes must be formatted using NTFS. - Pass
- V-253275 - Internet Information System (IIS) or its subcomponents must not be installed on a workstation. - Pass
- V-253284 - Structured Exception Handling Overwrite Protection (SEHOP) must be enabled. - Fail
- V-253305 - Reversible password encryption must be disabled. - Pass
- V-253382 - Solicited Remote Assistance must not be allowed. - Fail
- V-253386 - Autoplay must be turned off for non-volume devices. - Fail
- V-253387 - The default autorun behavior must be configured to prevent autorun commands. - Fail
- V-253388 - Autoplay must be disabled for all drives. - Fail
- V-253411 - The Windows Installer feature "Always install with elevated privileges" must be disabled. - Fail
- V-253416 - The Windows Remote Management (WinRM) client must not use Basic authentication. - Fail
- V-253418 - The Windows Remote Management (WinRM) service must not use Basic authentication. - Fail
- V-253453 - Anonymous enumeration of SAM accounts must not be allowed. - Pass
- V-253454 - Anonymous enumeration of shares must be restricted. - Fail
- V-253456 - Anonymous access to Named Pipes and Shares must be restricted. - Pass
- V-253461 - The system must be configured to prevent the storage of the LAN Manager hash of passwords. - Pass
- V-253462 - The LanMan authentication level must be set to send NTLMv2 response only, and to refuse LM and NTLM. - Fail
- V-253481 - The "Act as part of the operating system" user right must not be assigned to any groups or accounts. - Pass
- V-253485 - The "Create a token object" user right must not be assigned to any groups or accounts. - Pass
- V-253490 - The "Debug programs" user right must only be assigned to the Administrators group. - Pass

Manual Checks

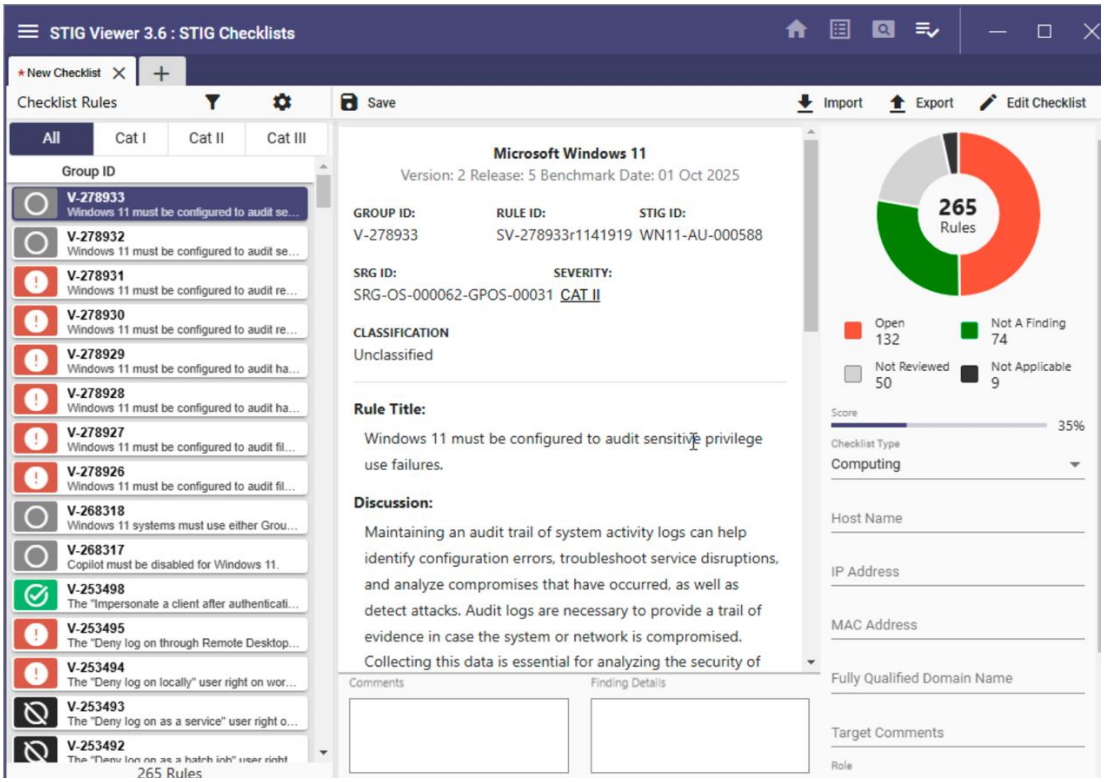
Results: Medium Severity (CAT II)

Automated Checks

- V-253254 - Domain-joined systems must use Windows 11 Enterprise Edition 64-bit version. - Not Applicable
- V-253261 - Windows 11 systems must use a BitLocker PIN with a minimum length of six digits for pre-boot authentication. - Fail
- V-253277 - Simple TCP/IP Services must not be installed on the system. - Pass
- V-253278 - The Telnet Client must not be installed on the system. - Pass
- V-253279 - The TFTP Client must not be installed on the system. - Pass
- V-253285 - The Windows PowerShell 2.0 feature must be disabled on the system. - Fail
- V-253286 - The Server Message Block (SMB) v1 protocol must be disabled on the system. - Pass
- V-253287 - The Server Message Block (SMB) v1 protocol must be disabled on the SMB server. - Pass
- V-253288 - The Server Message Block (SMB) v1 protocol must be disabled on the SMB client. - Pass
- V-253289 - The Secondary Logon service must be disabled on Windows 11. - Fail
- V-253297 - Windows 11 account lockout duration must be configured to 15 minutes or greater. - Fail
- V-253298 - The number of allowed bad logon attempts must be configured to three or less. - Fail
- V-253299 - The period of time before the bad logon counter is reset must be configured to 15 minutes. - Fail
- V-253300 - The password history must be configured to 24 passwords remembered. - Fail
- V-253301 - The maximum password age must be configured to 60 days or less. - Pass

SCAP Scan results interface showing compliance status and severity classification based on STIG benchmarks.

The SCAP Results file can be imported into STIG viewer to update the checklist created earlier to review



- Not a finding (NF): The system complies with the STIG requirement.
- Open (O): The system does not meet the requirement and requires remediation
- Not Applicable (NA): The control does not apply to the system configuration
- Not Reviewed (NR): The control was not evaluated during this assessment

4. <u>Summary</u>

Majority of failed checks were related to local security policies and auditing configurations. Remediation efforts focused on addressing high impact in easily configurable findings.

After remediation of follow up scan is encouraged to validate corrective actions to demonstrate improvement in compliance

5. *Conclusion*

STIGs and SCAP work together to establish and validate system security. STIGs essentially define what "secure" means, serving as the authoritative baseline, while SCAP automates the assessment of those requirements, providing consistent and repeatable compliance results.